

Best Deception Protection for Active Directory

 fidelissecurity.com/threatgeek/deception/best-deception-protection-for-active-directory

Doron Kolton

July 1, 2020



Table of Contents

Active Directory (AD) is one of the most crucial resources for most enterprises in managing their IT infrastructure. It is one of the most common IT control systems in use. It includes information such as hosts, user accounts, names, passwords, phone numbers, and so on, and enables authorized users to access this information^[1]. [Active Directory](#) makes this information easy to access and use for administrators and users.

Active Directory is a target for attackers following their initial foothold into an organization and infecting its assets. The [attackers perform reconnaissance](#) to map and identify the resources in the organization – the information that can be retrieved from AD is what they need for ruling the organization and moving laterally to other assets, thus expanding their initial reach.

Read on to explore difference [approaches to secure active directory](#):

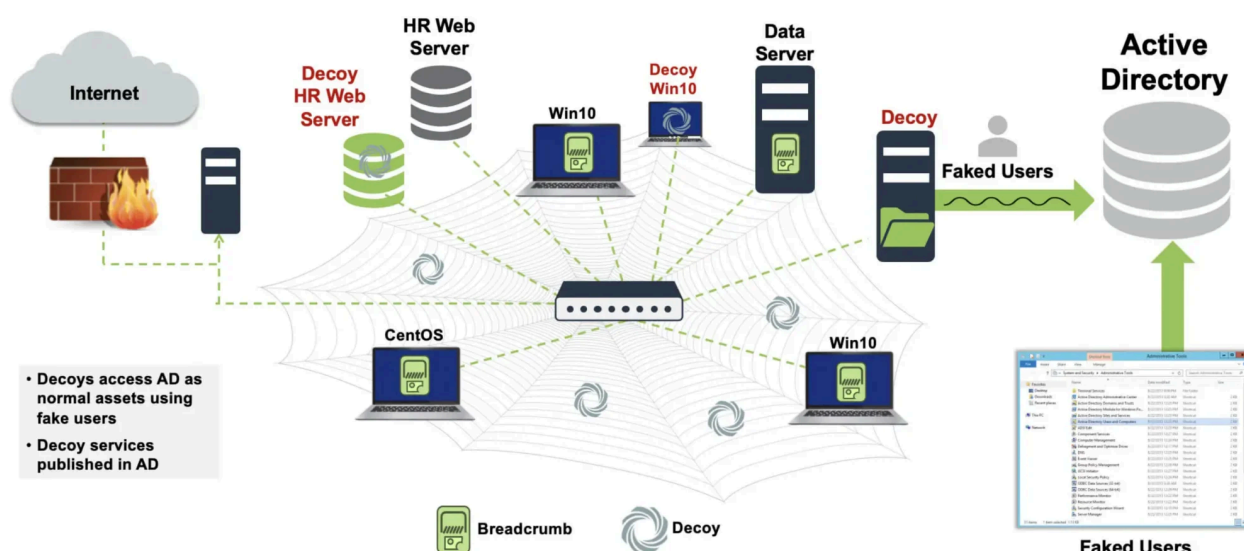
What are the different deception approaches to prevent an attack on Active Directory?

Approach (1) When evaluating the different options for Active Directory [deception](#), consider deploying an AD decoy; this decoy should be very similar to the real AD system the organization is using so the interaction between the attackers and the Active Directory decoy would look legitimate. Building a mirrored AD decoy that would update in real-time with assets and users' activities is not a trivial task, especially since the attackers are checking the relevancy of the information.

Assuming a good mirrored AD decoy is deployed, the next challenge is to direct attackers to reach out to the mirrored AD decoy rather than the real AD. Deploying breadcrumbs on assets as lures points the attackers in the direction of the AD decoys. This can be implemented in different methods but the idea behind it is similar. For this option to succeed, the attackers must use breadcrumbs found on the infected asset. If the attacker lands on an asset that does not carry the relevant breadcrumbs, its accesses to the AD cannot be detected.

Approach (2) However, every asset can query and collect data from AD. Thus, when attackers infect an asset, they can query the AD from the infected asset without raising suspicion. The attackers can collect the information and identify high privilege accounts and use these credentials to access other resources. The attackers can use queries or tools like Bloodhound to collect the information. To deceive the attackers, you need to populate the AD with information and trails of fake, high privilege accounts. This is achieved by seeding fake accounts in AD and binding these accounts to decoys in the organization. These decoys are operating as any other resource in the organization, i.e. performing login/logout, publicizing the services they provide and more. The attackers that query the AD see these accounts and use it to access the decoys and other assets in the organization. Using the fake credentials reveals the attackers' activities and presence on the infected assets. This approach can be complemented by planting faked credentials on assets in memory and in Windows Credential Manager like approach (1); attackers that infect assets where these credentials are deployed will also utilize these fake credentials. Analyzing their usage reveals the infected assets.

The second approach provides wider coverage as it does not rely only on the attackers finding the fake credentials on the infected assets. It detects attackers accessing the Active Directory from any infected asset or high privilege account, without relying only on fake credentials deployed on assets.



How Fidelis Deceptions Covers Active Directory Attack Attempts

[Fidelis Deception](#) leads with the second approach alongside the first approach, and institutes the following:

- Deploy decoys in the network like assets in the organization.
- Deploy memory lures and Credential Manager lures.
- Define fake users in AD that are using the same template and information as other users in the organization. These fake users cover different privilege levels.
- Fake users are “binded” to the decoys.
- Periodically the decoys access the Active Directory to login/logout and publicize the different services they use.
- Attackers querying the Active Directory find the decoys and fake users and can use the credentials to access decoys and/or other assets in the organization.
- High fidelity alerts are triggered for accessing the decoys and analyzing the Active Directory logs.

[Deception technology](#) is a critical component to enhancing your cybersecurity arsenal, but it's also the newest technology on the market right now.

If you're curious to learn more about our [award-winning Fidelis Deception technology](#), contact us to [schedule a demo](#).

Citations:

1. <https://docs.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>

One Platform for All Adversaries
